

Guía Metodológica de la Encuesta PASTA+STRIDE

Diseño, fundamentación y uso de resultados

1. Propósito general

Esta encuesta persigue medir la madurez de las organizaciones en el uso de metodologías de modelado de amenazas (especialmente PASTA y STRIDE) y su integración en la gestión del riesgo cibernético y la resiliencia del negocio.

Se alinea con:

- Las mejores prácticas de modelado de amenazas recomendadas en la comunidad internacional (PASTA, STRIDE, SAMM, etc.).[web:18][web:39]
- Tendencias de madurez y gobernanza de ciberseguridad observadas en informes de referencia en España (Deloitte, ISMS Forum, etc.).[web:8][web:31][web:37]
- Requisitos de marcos normativos como NIS2, DORA, ENS y RGPD, que enfatizan el enfoque basado en riesgo y la protección de servicios esenciales.[web:21][web:24][web:27]

2. Estructura conceptual

La encuesta se organiza según las fases de PASTA y la clasificación de amenazas de STRIDE:

- Fases PASTA: objetivos de negocio, alcance técnico, descomposición, análisis de amenazas, vulnerabilidades, simulación de ataques, análisis de riesgo e impacto.[web:18]
- STRIDE: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege.[web:18][web:28]

Además, se añaden dimensiones transversales:

- Gobernanza y alineamiento con negocio.
- Zero Trust y cadena de suministro.
- Talento, herramientas y automatización.
- Medición de madurez global y ROI.

3. Diseño de las preguntas

Las preguntas combinan:

- Preguntas de selección única o múltiple para medir presencia/ausencia y tipos de prácticas.
- Escalas de Likert (1–5) para medir grado de madurez o frecuencia.
- Preguntas abiertas para capturar contexto, fricciones y matices organizativos.

El diseño evita, en la medida de lo posible, preguntas que puedan resolverse con “cumplimos el papel” y obliga a distinguir entre práctica real y documentación formal.

4. Población objetivo y unidad de análisis

- Población: organizaciones públicas y privadas con actividad en España, con especial interés en aquellas sujetas a regulaciones de ciberseguridad (NIS2, DORA, ENS, sectores críticos).
- Respondentes previstos: CISO, responsables de seguridad o de riesgo, personas con visión transversal de TI y negocio.
- Unidad de análisis: organización como conjunto; opcionalmente, se puede pedir que la respuesta se refiera a un perímetro concreto (grupo, país, unidad de negocio).

5. Escalas de madurez y construcción del Índice Global de Madurez (IGM)

La encuesta está diseñada para alimentar un Índice Global de Madurez (IGM) compuesto por varias subescalas:

1. Gobernanza y estrategia (GOV)
Ítems: 2.1.x, 2.2.x, 9.1.x, 9.1.3.
2. Cobertura y calidad del modelado de amenazas (TM)
Ítems: 4.1.x, 5.1.x, 6.1.x, 6.2.x.
3. Gestión de vulnerabilidades y simulaciones (VULN/SIM)
Ítems: 7.1.x, 8.1.x, 8.1.3.
4. Integración en riesgo, continuidad y ROI (RISK/ROI)
Ítems: 9.1.x, 9.1.2, 9.1.4.
5. Capacidades habilitadoras (CAP)
Ítems: 10.1.x, 11.1.x, 11.1.3, 11.1.4.

Cada subescala puede normalizarse en 0–100 y contribuir al IGM ponderado (ver plantilla de Excel).

6. Lógica de puntuación (visión general)

- Preguntas en escala 1–5: se transforman linealmente a 0–100.
- Preguntas categóricas: se asignan valores ordinales (p. ej. “Sí, plena” = 100; “No” = 0; “En fase” = valores intermedios).
- Preguntas abiertas: no puntúan, pero informan interpretación cualitativa y pueden alimentar análisis temático.

Se recomienda documentar las reglas de puntuación en un anexo técnico y mantenerlas estables para comparaciones longitudinales.

7. Recolección de datos y garantías de calidad

- Canal: plataforma online, formulario seguro o herramienta GRC.
- Duración estimada: 20–30 minutos para respondentes familiarizados con ciberseguridad.
- Anonimización: en análisis comparativos (benchmark), anonimizar nombres de organizaciones y detalles identificables.
- Validación: revisar respuestas inconsistentes (p. ej. declarar “no hacemos modelado” y, a la vez, contestar extensamente a secciones muy técnicas).

8. Interpretación de resultados

El IGM y sus subíndices no son un juicio moral, sino un mapa.

Algunos ejemplos de lectura:

- Una organización con GOV alto y TM bajo suele tener buena intención estratégica, pero poco aterrizaje técnico: un clásico.
- Una organización con SIM alto y RISK/ROI bajo tiende a realizar ejercicios interesantes cuyo impacto en decisiones de negocio es mínimo (teatro de seguridad).
- Niveles bajos en CAP suelen indicar que la organización se sostiene sobre héroes individuales y hojas de cálculo, lo cual no escala ni en número ni en resiliencia.

9. Comparación con estudios e índices existentes

La estructura de madurez puede compararse con:

- Indicadores de madurez en ciberseguridad publicados por ISMS Forum (niveles Básico, Intermedio, Avanzado) y su evolución en España.[web:31][web:33]
- Estudios internacionales de preparación en ciberseguridad que muestran que sólo una minoría de organizaciones alcanzan niveles “maduros”. [web:38][web:40]
- Informes sectoriales sobre gobernanza y alineamiento de negocio y seguridad.[web:8][web:37]

10. Uso estratégico del instrumento

A nivel macro (gobierno, asociaciones, reguladores):

- Medir la penetración real de prácticas de modelado de amenazas en el tejido empresarial.
- Identificar sectores con brechas significativas y orientar ayudas, formación y regulación.

A nivel micro (organizaciones individuales):

- Priorizar inversiones (herramientas, talento, automatización) en función de brechas de madurez.
- Conectar de forma argumentada el presupuesto de ciberseguridad con impacto en riesgo y resiliencia.
- Alimentar cuadros de mando y reportes a la Alta Dirección y al Consejo.

11. Limitaciones y precauciones

- Es un instrumento de auto-reporte: propenso al optimismo antropológico. Se recomienda contrastar resultados con auditorías y evidencias.
- No sustituye a evaluaciones técnicas ni a análisis forense de incidentes, pero ayuda a prevenirlos.
- El exceso de cinismo puede llevar a infravalorar la utilidad de medir; el exceso de complacencia, a sobrevalorar números que no se corresponden con la realidad operativa.

Fin de la guía. No hace milagros, pero ayuda a que los milagros que se atribuyen a la “suerte” tengan algo más que ver con el trabajo bien hecho.